

VAPT REPORT

Metasploitable Vulnerable Virtual Machine

Assessment Type	Vulnerability Assessment and Penetration Testing
Target	Metasploitable VM
Target IP	192.168.1.31
Environment	Controlled laboratory environment
Primary Tool	Nmap
Additional Tool	Metasploit Framework
Assessment Date	30 August 2026
Overall Risk	CRITICAL

1. Executive Summary

A vulnerability assessment was performed against the Metasploitable virtual machine at 192.168.1.31. The assessment identified numerous exposed services and several known security vulnerabilities. The most significant finding was the vsFTPD 2.3.4 backdoor vulnerability (CVE-2011-2523) on TCP port 21. Nmap identified this vulnerability as exploitable and its check reported uid=0(root), indicating potential root-level compromise in the laboratory target.

Other significant findings included a vulnerable Java RMI registry on port 1099, weak TLS/Diffie-Hellman configurations, and multiple potentially vulnerable web applications and forms.

2. Scope

Item	Details
Target	Metasploitable VM
IP Address	192.168.1.31
Environment	Controlled lab
Network Assessment	Included
Web Services	Included
Vulnerability Enumeration	Included
Exploitation	Limited to authorized lab environment

3. Methodology

The assessment followed reconnaissance, port and service enumeration, vulnerability identification, validation of selected findings, risk assessment, and remediation recommendation.

The vulnerability enumeration command used was:

```
nmap --script vuln 192.168.1.31
```

4. Open Ports and Services

Port	Service	Risk
21	FTP	Critical

Port	Service	Risk
22	SSH	Medium
23	Telnet	High
25	SMTP	Medium
53	DNS	Medium
80	HTTP	High
111	RPC	Medium
139	NetBIOS	High
445	SMB	High
512/513/514	rexec / rlogin / rsh	High
1099	Java RMI	Critical
1524	ingreslock	High
2049	NFS	High
2121	FTP	High
3306	MySQL	High
5432	PostgreSQL	High

5. Vulnerability Findings

Finding 1 — vsFTPD 2.3.4 Backdoor

Severity: Critical **Port:** TCP/21 **CVE:** CVE-2011-2523

Nmap identified the vsFTPD 2.3.4 backdoor and explicitly classified it as VULNERABLE (Exploitable). The vulnerability check reported uid=0(root) gid=0(root).

Impact: Successful exploitation can result in unauthorized remote access with extremely high privileges.

Recommendation: Remove/replace the backdoored version, disable FTP if unnecessary, restrict access with firewall controls, and review the system for unauthorized changes.

Finding 2 — Java RMI Registry Remote Code Execution

Severity: Critical **Port:** TCP/1099

Nmap reported a vulnerable RMI registry configuration. The finding states that the default configuration may permit loading classes from remote URLs, potentially resulting in remote code execution.

Recommendation: Disable RMI if unnecessary, restrict port 1099 to trusted hosts, apply security updates, and disable remote class loading where possible.

Finding 3 — SSL POODLE

Severity: High **CVE:** CVE-2014-3566

The scan identified SSLv3-related POODLE exposure. Weak SSLv3 configurations can expose encrypted communications to information-disclosure attacks under appropriate conditions.

Recommendation: Disable SSLv3, require modern TLS versions, remove weak cipher suites, and upgrade outdated SSL/TLS libraries.

Finding 4 — Weak Diffie-Hellman / Logjam

Severity: High **CVE:** CVE-2015-4000

The scan identified export-grade Diffie-Hellman configuration and Logjam exposure, along with insufficient-strength DH groups.

Recommendation: Disable export-grade cryptography, use sufficiently strong DH parameters, disable weak/legacy cipher suites, and upgrade affected cryptographic libraries.

Finding 5 — Web Application Security Issues

Severity: High

The HTTP service exposed deliberately vulnerable applications including DVWA, Mutillidae, TikiWiki, phpMyAdmin, phpinfo, and TWiki-related resources. Nmap also reported possible CSRF and SQL-injection findings in the web applications.

Recommendation: In production, remove intentionally vulnerable applications, patch web applications, use secure input validation and parameterized SQL queries, implement CSRF protection, restrict administrative interfaces, and remove unnecessary information-disclosure files.

6. Risk Summary

Finding	Severity	Potential Impact
vsFTPD 2.3.4 Backdoor	Critical	Root-level compromise
Java RMI RCE	Critical	Remote code execution

Finding	Severity	Potential Impact
SSL POODLE	High	Information disclosure
Weak DH / Logjam	High	Cryptographic compromise
Vulnerable Web Applications	High	Application/data compromise
Telnet/rlogin/rsh	High	Credential/session exposure
SMB/NetBIOS exposure	High	Increased attack surface
NFS exposure	High	Unauthorized resource access

7. Remediation Priority

Immediate: Replace vsFTPD 2.3.4; disable/restrict Java RMI; disable Telnet/rlogin/rsh; patch or remove vulnerable web applications.

Short Term: Upgrade TLS configuration; remove weak DH parameters and export ciphers; restrict SMB/NFS access; apply host firewall rules; perform an authenticated vulnerability scan.

Long Term: Establish patch management, continuous service monitoring, periodic vulnerability assessments, network segmentation, and secure configuration baselines.

8. Conclusion

The Metasploitable VM has a critical security posture, with multiple avenues for unauthorized access. The strongest evidence is the vsFTPD 2.3.4 backdoor, which the scan directly identified as exploitable and for which the check reported root-level command execution. The VM is intentionally vulnerable and should remain isolated from untrusted networks.

Prepared for controlled security-training/laboratory use.